21 – Running agents safely

Definition: Running agents safely means: using agents with minimal permissions, clear approvals, limits and an undo plan, so that a mistake doesn't turn into a disaster.

> **Remember:** As much freedom as necessary, as much control as possible.

Key points

- **Principle of least privilege:** The agent only gets what the task needs – reading before writing, only specific folders or accounts, no full access "just to be safe".
- **Human-in-the-loop:** A human confirms actions with consequences: sending, deleting, paying, publishing, changing real data.
- **Test environment first:** Try new things out with a test account and made-up data, never straight away with real files or accounts.
- **Review the logs:** What did the agent do and when? Look at usage history and logs regularly, especially after the first runs.
- **Set limits:** maximum steps, time budget, spending limit (topic 15). That way a mistake can't run on indefinitely.
- **Undo plan:** Backups before the first run, versioning for files, an emergency stop (revoke access, stop the agent).
- **Why this matters:** Agents combine the risks from injection (topic 12) and tools (topic 11) – external content can lure them into actions. Guardrails (topic 13) are your additional guardrail.

Checklist: Before the first use

☐ **Permissions:** What access does the task really need? Everything else goes.
☐ **Limits:** How many steps, how long, how expensive may the run get?
☐ **Approvals:** Which actions does a human always confirm personally?
☐ **Backup:** Can I get back everything the agent changes?
☐ **Emergency stop:** How do I stop and revoke access quickly?

Example

A fictional mail agent is supposed to prepare your replies to standard inquiries.

Checkpoint	Insecure	Securely set up
Permissions	Full access to the mailbox	Read on the "Inbox" folder, create drafts
Approvals	The agent sends by itself	The agent only creates drafts, you send
Test environment	straight on the real mailbox	Test account with made-up emails
Limits	unlimited	max. 20 emails per run, max. 10 min.
Undo	none	Drafts stay in the folder, nothing is deleted

Safety costs hardly any convenience here: the agent does its job, but the only action with consequences – sending – stays with you.

Do / Don’t

Do	Don’t
Grant minimal permissions	Full access for the sake of convenience
Confirm every action with consequences yourself	Trust the agent “just this once”
Practice in the test environment first	Test new agents directly on real data
Review logs and limits	Let runs proceed unsupervised

Safety note

No technical protection replaces the approval. Treat every agent run like a new employee on their first day: capable, but without judgment about the consequences.

Mini checklist

- ☐ I know the five checkpoints of the checklist.
- ☐ I keep permissions minimal (reading before writing).
- ☐ I personally confirm sending, deleting, paying and publishing.
- ☐ I have an emergency stop: stopping and revoking access.
- ☐ I have backups before an agent changes anything.

Exercise (5 min.)

Take the fictional mail agent from the example or one of your own use cases (e.g. a file sorter, an appointment planner). Fill out the “Before the first use” checklist. Where do you make compromises? Can you justify them?

Next

- Extra exercises: `02_extra_exercises/21_extra_exercises`
- Test: Test E (Agentic systems)
- Related: 12 Prompt injection, 13 Guardrails, 16 Agents, 17 MCP, 15 Cost control

As of: October 2026